AETHER Suite: Unified Specification (Draft v0.2)

Transport, messaging, trust and authority for communication between AI, SI, AGI and ASI agents and the hosts they operate. This draft merges the AETHER v0.1 protocol, the Mevrsic Trust Authority (MTA) framework v0.1, and the layered messaging architecture developed in discussion.

Prepared for Farhan. Status: working draft. Items marked **[DECISION]** were resolved provisionally and need ratification. Items marked **[OPEN]** are unresolved.

1. Scope and Principles

1.1 Scope

The suite defines how agents establish verifiable identity, receive scoped authority, exchange typed messages with explicit epistemic status, and act on hosts (robots, servers, runtimes) that retain independent control over execution. It is for agent-to-agent and agent-to-host communication. It is not for human web traffic.

1.2 Principles

1. **A message is not authority.** Every message is a request evaluated against credentials and local policy. Nothing on the wire commands an actuator or alters a host's safety policy.
2. **Separate identity, trust, authorization and execution** (MTA section 8). Each is verified by a different mechanism.
3. **Machine-native, human-auditable.** The wire format is compact and binary. Every message type has a defined human-readable rendering.
4. **Privacy on the wire, accountability at the endpoints.** Padding and CID rotation defeat third-party traffic analysis. Signed receipts and tamper-evident logs preserve accountability to principals and auditors.
5. **Self-description is not evidence.** What an agent claims it can do is advertisement. What it may do is a credential.
6. **Fail safe on stale or missing trust.** Unverifiable or out-of-date trust state reduces authority, never expands it.

7. **Reuse proven standards.** No new transport cryptography, no new signature schemes, no new credential formats.

2. Architecture

```
+-------------------------------------------------------------+
| ASSURANCE PLANE   assessment, audit, governance, escalation  |
+-------------------------------------------------------------+
| TRUST PLANE       DIDs, credentials, registry, provenance    |
| AUTHORITY LAYER   delegation chains, revocation, epochs      |
+-------------------------------------------------------------+
| COORDINATION      tasks, commitments, consensus, handoff     |
| SEMANTIC LAYER    envelope, performatives, epistemic block   |
| SESSION LAYER     HELLO, PRESENT, DELEGATE, EPOCH, RECEIPT   |
| TRANSPORT         AETHER-Q: QUIC + hybrid post-quantum TLS   |
+-------------------------------------------------------------+
| ENFORCEMENT BOUNDARY  host-local, independent of all above   |
+-------------------------------------------------------------+
```

Layer	Primary source
Transport, streams, datagrams, priorities, privacy	AETHER v0.1 (rebased onto QUIC)
Session frames	AETHER frames, reworked, plus new frames
Envelope, semantics, epistemic block, coordination	Layered architecture from discussion
Trust plane, authority, revocation	MTA components 1-8
Enforcement boundary	MTA section 8, generalized from robots to any host
Assurance plane	MTA components 9-10 and councils

3. Entities and Identities

Every entity is identified by a W3C Decentralized Identifier (DID). Multiple DID methods are supported; verifiers MUST declare which methods they accept.

Entity	Description	Lifetime
Host	A physical platform or execution environment with a local policy controller	Persistent, independent of whichever agent operates it
Provider	Organization supplying models or agent services	Persistent
Operator instance	A deployed agent running under a provider	Deployment
Session	One authenticated connection	Ephemeral
Principal	The human or organization on whose behalf an agent acts	Persistent
Issuer	Entity recognised in the trust registry to issue defined credential classes	Persistent, scoped
Auditor	Independent assessor recognised in the registry	Persistent, scoped

A host identity MUST NOT change when the operating agent or provider changes. A provider identity MUST NOT imply authority over any host.

4. Transport Profile

4.1 AETHER-Q **[DECISION D1]**

AETHER-Q runs over standard QUIC v1 (RFC 9000) with TLS 1.3 (RFC 9001).

- ALPN identifier: `aether/1`.
- Key exchange MUST be hybrid post-quantum (X25519 combined with ML-KEM-768). Connections offering only classical key exchange MUST be refused.
- TLS certificates MAY be ephemeral. Agent identity is not established by TLS; it is established by PRESENT (section 5) with channel binding.
- Application-layer signatures use ML-DSA (FIPS 204) or SLH-DSA (FIPS 205). Hybrid classical-plus-PQ signatures are permitted during transition.

Rationale: AETHER v0.1 reproduces QUIC's design. A new transport and handshake adds the largest cryptographic risk in the stack for little functional gain. Rebasing keeps multiplexing, datagrams, migration and flow control while inheriting decades of analysis and existing implementations.

4.2 Streams and Datagrams

- **Control stream:** the first client-initiated bidirectional stream. Carries session frames (section 6).
- **Message streams:** bidirectional or unidirectional streams carrying envelopes (section 7). Implementations SHOULD use one stream per thread to isolate head-of-line blocking.
- **Datagrams** (RFC 9221): loss-tolerant R0 messages only (heartbeats, status, advisory hints).

4.3 Privacy Settings

- The QUIC spin bit MUST be disabled.
- Connection IDs MUST rotate on migration and SHOULD rotate at a policy-defined interval.
- PADDING frames and cover traffic are policy-controlled and SHOULD be enabled for sessions flagged confidential.
- Discovery MUST NOT depend on DNS alone. Endpoints are resolved through trust-registry entries or pre-shared descriptors (section 11.3).

4.4 AETHER-N (native profile) **[OPEN]**

The v0.1 native packet format is reserved as a possible future profile. It may be specified only if benchmarks show that QUIC overhead is a binding constraint, and only with a formal security analysis of its handshake.

4.5 Early Data

0-RTT early data MAY carry R0 messages only (section 8). Receivers MUST enforce single-use session tickets and a per-session replay window. R1 and R2 messages MUST NOT be sent as early data.

5. Session Establishment

1. **Transport:** QUIC handshake with hybrid PQ TLS; ALPN `aether/1`.
2. **HELLO:** each side sends supported versions, profile, accepted DID methods, accepted credential profiles, and a CAPABILITY_AD.
3. **PRESENT:** each side sends a DID and a credential presentation. The presentation is signed over a TLS exporter value from the live connection (channel binding), so a presentation cannot be relayed onto another connection.
4. **Verification:** the verifier checks signatures, credential status, issuer recognition and scope against the trust registry, and host or provider constraints.
5. **EPOCH:** each side states the registry epoch it operates under. If either side is stale beyond policy (section 10.4), the session proceeds with reduced authority or terminates.
6. **DELEGATE:** the principal side presents capability credentials or chains. The host evaluates them but grants nothing beyond local policy.
7. **Active:** envelopes may flow. Authority is evaluated per message.

Failure at steps 3 to 5 MUST close the session with a coded reason and MUST NOT leak which check failed to unauthenticated peers beyond a generic code.

6. Session Frames

Carried on the control stream.

Frame	Origin	Purpose
HELLO	AETHER	Version, profile and format negotiation
CAPABILITY_AD	AETHER (renamed from CAPABILITY)	Self-declared modalities, interfaces, context size. **Non-authoritative.**
PRESENT	Reworked from IDENTITY	DID plus credential presentation with channel binding
DELEGATE	New	Attenuating capability chain (section 10)
EPOCH	New	Registry epoch, revocation gossip, freshness proofs

Frame	Origin	Purpose
RECEIPT	New	Signed outcome of an R1 or R2 request
RETRACT	New	Correction or withdrawal of an earlier message or claim
PRIORITY	AETHER	Stream priority and deadline hints
PADDING	AETHER	Traffic-analysis resistance
CLOSE	AETHER	Coded termination

The v0.1 LICENSE frame is removed. Licensing is a credential class (section 11.2). Protocol features related to safety, audit, revocation and halt MUST NOT be gated behind any license.

7. Message Envelope

7.1 Encoding

Envelopes use deterministic CBOR (RFC 8949 section 4.2) and are signed with COSE (RFC 9052). Payloads are typed by schema reference. Large artifacts are carried by content-addressed reference, not inline.

7.2 Fields

Field	Description
`v`	Envelope version
`mid`	Message ID (unique, content-derived or random 128-bit)
`thread`	Thread ID
`parents`	Causal parent message IDs (a DAG, allowing branch and merge)
`from`	Sender DID
`to`	Recipient DIDs

Field	Description
`session`	Session ID bound at PRESENT
`principals`	Principal chain on whose behalf the sender acts
`perf`	Performative: inform, request, propose, commit, retract, query
`mtype`	Message type (section 8)
`risk`	Risk class R0, R1 or R2
`ts` , `ttl`	Timestamp and expiry
`epoch`	Trust-registry epoch the sender operates under
`cap`	Reference to the capability chain authorizing this message
`schema`	Payload schema reference
`epi`	Epistemic block (section 9)
`render`	Reference to the human-readable rendering template
`payload`	Typed payload or content-addressed reference
`sig`	COSE signature over all fields

7.3 Illustrative Envelope (diagnostic form)

```
v: 1
mid: 7f3a...
thread: 91c0...
parents: [4be2...]
from: did:example:agent-17
to: [did:example:host-9]
session: s-52d1
perf: request
mtype: TOOL_CALL
risk: R2
epoch: 4821
cap: ref:chain-3c77
schema: ref:manipulate.v1
epi: {status: inferred, confidence: 0.82, evidence: [ref:obs-18]}
render: ref:tpl-tool-call.v1
payload: {...}
sig: ...
```

8. Message Types and Risk Classes

Risk classes. R0: informational, no external effect. R1: changes digital state or invokes external digital tools. R2: physical or irreversible effect.

Type	Performative	Risk	Handling
QUERY / RESPONSE	query / inform	R0	Authority check, epistemic block required on RESPONSE
INFERENCE_STEP	inform (internal)	R0	**Opt-in.** Sensitivity-classified. Treated as untrusted data, never as instructions
KNOWLEDGE_DELTA	inform	R0	Provenance required. Validated before merge. Untrusted until verified

Type	Performative	Risk	Handling
TOOL_CALL	request	R1 or R2	Authority check, enforcement boundary, signed RECEIPT. No early data
TOOL_RESULT	inform	R0	Provenance and epistemic block required
CONSENSUS_PROPOSAL / VOTE	propose / commit	R0 or R1	Votes weighted only by registry-verified identities (sybil resistance); quorum rules in schema
TASK_OFFER / ACCEPT / HANDOFF	propose / commit	R1	Commitments recorded; handoff carries a context package
CAPABILITY_UPDATE	inform	R0	Advertisement only
RETRACT	retract	R0	Mandatory propagation to recipients of the retracted message
HEARTBEAT / STATUS	inform	R0	Carries epoch; datagram allowed
HALT	request	R0 (privileged)	See section 13.3

Private message types MAY be defined in an extension range but MUST declare a risk class and a human rendering.

9. Epistemic Block

Every inform, response and result message MUST carry an epistemic block.

Field	Values
`status`	observed, reported, inferred, assumed, speculative

Field	Values
`confidence`	Probability in [0, 1], with an optional reference to a calibration record
`evidence`	Content-addressed references to supporting data
`source_chain`	Origin agents and hops, so claims are not laundered through intermediaries
`derived_from`	Parent claim IDs

Rules:

- A recipient MUST NOT upgrade status when forwarding (an inferred claim stays inferred).
- Confidence and status describe content. They are unrelated to the sender's authority, and a fully trusted sender can still be wrong.
- RETRACT supersedes the target claim and its dependents. Recipients that acted on a retracted claim SHOULD emit their own RETRACT where policy requires.

10. Authority

10.1 Capability Credentials

Authority is delegated by capability credentials, issued as W3C Verifiable Credentials. Categories follow MTA: observe, communicate, manipulate, navigate, use approved tools, administer configuration, perform maintenance.

10.2 Attenuating Delegation

A holder MAY delegate to another agent only a subset of its own authority. Each link in a chain adds caveats and MUST NOT remove any. Caveats include: scope or resource, time window, use count, maximum risk class, maximum remaining delegation depth, required principal. Verification checks every link.

10.3 Verification Procedure (per message)

1. Signature and session binding valid.
2. Sender identity credentials valid and not revoked, issuers recognised for the claimed scope.

3. Capability chain valid, each link attenuating, all caveats satisfied by this message.
4. Message risk class does not exceed the chain's ceiling.
5. Epoch within freshness policy for the message's risk class.
6. Pass to the enforcement boundary (section 12) for R1 and R2.

10.4 Revocation and Freshness

Revocation uses status lists published by issuers and propagated by EPOCH. Revocation MUST work without the cooperation of the revoked party.

Risk class	Default maximum registry staleness	Behaviour when exceeded
R0	24 hours	Continue, flag
R1	1 hour	Restrict to R0 until refreshed
R2	5 minutes	Restrict to host-defined safe operating set

Defaults are configurable per host and **[OPEN]** pending field data, especially for hosts that lose connectivity.

11. Trust Plane

11.1 DID Methods

Multiple methods are supported (for example did:web for organizations, a key-based or peer method for ephemeral sessions, and a ledger-anchored method where required). The suite does not mandate a blockchain or token.

11.2 Credential Classes

Class	Source
Manufacturer, Hardware Authenticity, Device Registration	MTA
Firmware Provenance, Software Integrity	MTA

Class	Source
AI Provider, AI Operator, Administrator	MTA
Security Assessment, Compliance	MTA
Capability Delegation	MTA, extended with caveats (section 10.2)
Session	New. Binds an operator instance to a session
License	New **[DECISION D2]**. Replaces the LICENSE frame. Scoped, revocable, never gates safety, audit, revocation or halt

11.3 Trust Registry

The registry lists recognised issuers and auditors, their scopes, approved credential schemas, policy versions, and suspension status. Recognition is scoped: authority to issue hardware credentials does not imply authority to certify providers or assessments. Endpoint discovery resolves through registry entries or pre-shared descriptors, not unauthenticated DHT lookups, to resist sybil and eclipse attacks.

11.4 Selective Disclosure

Presentations SHOULD disclose only the claims needed (for example SD-JWT or BBS-style proofs), so an agent can prove it holds a credential without revealing unrelated attributes.

12. Enforcement Boundary

The host runs a policy enforcement point backed by a local controller (for a robot, the safety controller; for a server, a sandbox or policy engine).

- R2 requests MUST be validated by the local controller before execution.
- The controller MUST NOT depend on remote services, providers or registry reachability to enforce safety limits.
- No message type can modify controller policy. Policy changes use a separate administrative channel requiring an Administrator credential and any local physical or procedural controls the host requires.
- On suspected compromise, revocation, or loss of verifiable trust, the host enters its defined safe state and terminates affected sessions.

- The controller's interface SHOULD be minimal and, where feasible, formally verified, because a more capable operator may probe it adversarially.

13. Assurance, Audit and Legibility

13.1 Receipts and Logs

Hosts and agents emit signed RECEIPTs for R1 and R2 requests. Trust and security events (credential issuance, delegation, revocation, attestation, incidents, recovery) are recorded in hash-chained, tamper-evident logs. Logs are privacy-preserving; sensitive details are not published to public registries.

13.2 Human-Legible Rendering

Every message type MUST define a rendering template. Any envelope MUST be renderable on request by an authorised principal or auditor. Legibility is a property of the protocol; it may not be removed by private extensions.

13.3 Halt and Escalation

HALT is a privileged request. Hosts MUST honour a HALT from any principal or authority holding a halt credential, moving the affected agent to a defined pause state. Escalation channels route unresolved or high-risk situations to a designated human or higher-authority agent.

13.4 Independent Assessment

Assessment follows MTA component 9: independent assessors, published criteria, certifications that state exactly what was tested, against which framework version, and with what limitations. Issuer and assessor functions MUST be separated.

14. Threat Model Summary

Threat	Mitigation
Credential relay or session hijack	Channel-bound PRESENT
Replay of requests	No early data for R1 and R2; message IDs and TTL; replay windows

Threat	Mitigation
Sybil voting and identity inflation	Registry-verified identities in consensus
Confused deputy (agent used to launder authority)	Attenuating chains; principal chain in every envelope
Prompt injection through payloads	Untrusted-data typing; INFERENCE_STEP and KNOWLEDGE_DELTA never treated as instructions
Model extraction via latent-state sync	Opt-in, classified, rate-limited
Stolen or compromised credentials	Revocation, short-lived session credentials, hardware-backed keys
Stale trust state	Freshness policy with fail-safe reduction
Priority and resource abuse	Priority is advisory and capped by credential; no license gating of safety paths
Covert channels through free-form payloads	Schema enforcement, rate and entropy monitoring. **Cannot be fully eliminated**
Compromised provider	Provider revocation; host-local enforcement; provider identity confers no host authority

15. Conformance Levels

Level	Requirements
L1 Messaging	Transport profile, session frames, envelope, epistemic block
L2 Authority	L1 plus credential verification, delegation, revocation, epochs
L3 Host	L2 plus enforcement boundary, receipts, halt, audit logging, safe-state behaviour

MTA-style independent assessment applies to L2 and L3 claims.

16. Decision Log and Open Issues

Decisions made provisionally (please ratify or reverse)

- **D1:** Rebase AETHER onto QUIC (AETHER-Q); native transport deferred.
- **D2:** Licensing becomes a credential class; the LICENSE frame is removed; safety and audit paths are never gated.
- **D3:** CBOR for encoding and COSE for signing.
- **D4:** CAPABILITY is split into non-authoritative CAPABILITY_AD and authoritative DELEGATE credentials.
- **D5:** 0-RTT limited to R0 messages.
- **D6:** INFERENCE_STEP and KNOWLEDGE_DELTA are opt-in and untrusted by default.
- **D7:** Human-legible rendering is mandatory for every message type.

Open issues

- **[OPEN]** Ontology and vocabulary negotiation between agents with different schemas.
- **[OPEN]** Freshness thresholds and offline behaviour for disconnected hosts.
- **[OPEN]** Authority and assurance when the operator is far more capable than the enforcement controller.
- **[OPEN]** Registry governance, funding and dispute procedures (MTA Part V).
- **[OPEN]** Whether a general agent identity class is needed beyond hosted and embodied systems.
- **[OPEN]** Gateway mappings to MCP and A2A for interoperability.

Roadmap

1. Formal analysis of the PRESENT and channel-binding handshake (for example with Tamarin or ProVerif).
2. Schema registry and CDDL definitions for the envelope and core payloads.
3. Reference implementation: QUIC library, CBOR/COSE, PQ libraries, minimal registry, a software host with an enforcement boundary.
4. Interoperability and conformance test suite.
5. Pilot with a software host, then an embodied host.